

NEWSLETTER N. 512 of October 23, 2023

The Privacy Authority fines an energy company

10 million euros

Promotional SMS without consent: a telematic university sanctioned

Inadequate security measures: the Authority sanctions a Local Health Authority

Digital euro: privacy authorities demand greater guarantees for citizens

The Privacy Authority fines an energy company for

10 million euros

Unrequested contracts activated with inaccurate and outdated data

The Privacy Authority has imposed a fine of 10 million euros on Axpo Italia Spa, an electricity and gas supplier, for the activation of unrequested contracts in the free market through the processing of inaccurate and outdated customer data.

The company, which unlawfully processed the personal data of over 5,000 users, will have to adopt a series of technical and organizational measures prescribed by the Authority to comply with Italian and European data protection regulations.

The Authority intervened following numerous complaints from users who reported the activation, unbeknownst to them, of electricity and gas contracts in their name, of which they became aware after receiving closure letters from the previous supplier or payment reminders for unpaid bills.

They particularly complained that their personal data (such as email address, phone number, and supply number) indicated in the contract were inaccurate or outdated.

Inspections carried out by the Authority revealed that the company acquired new contracts for electricity and gas supply through a network of about 280 door-to-door sellers (agents and sub-agents), without having equipped itself with suitable tools and procedures to ensure that the data entered by the sellers in its database corresponded to the actual users of the services (such as, for example, alert systems to detect procedural anomalies; control procedures for the agencies' operations; timely checks on the accuracy of the acquired data; etc.). These shortcomings led to the acquisition of unrequested contracts, often filled out with inaccurate and outdated personal data. A significant case involved a user who contested 23 activations on as many services having the same start and end date of supply.

Moreover, the company's database contained 2,462 contractual proposals in which the same email address of the potential customer was repeated more than five times.

The Authority therefore ordered Axpo Italia Spa to adopt a series of corrective measures, including the use of a blocking "check-call" system that allows for the verification of the correctness of contracts acquired through the seller network; the introduction of alert systems suitable for detecting any incorrect and/or fraudulent behavior in acquiring potential customers' data by sellers; the implementation of mechanisms to ascertain the actual receipt of communications sent to the customer during the contracting phase; and the adoption of procedural rules aimed at strengthening audit activities regarding the operations of the agencies.

Promotional SMS without consent: a telematic university sanctioned

A fine of 75,000 euros has been imposed by the Privacy Authority on a telematic university deemed responsible for sending promotional SMS without the consent of the recipients. The Authority also ordered the university to verify the technical and organizational measures adopted to demonstrate that it had obtained valid consent for the processing of data for promotional purposes, even in the case of outsourcing advertising campaigns to third parties. The university was also prohibited from using the data processed unlawfully.

The Authority's intervention follows complaints from several citizens who reported receiving unwanted SMS and, in one case, repeated promotional phone calls for 6 years, even after opposing such messages and receiving no response from the university.

The university, in fact, in violation of the EU Regulation and the Privacy Code, continued for years to send promotional messages without taking into account the rights of the recipients, despite numerous complaints received and never addressed. And especially without adopting measures to correct its

conduct, even after the initiation of the Authority's investigation, thus avoiding the repetition of the contested behaviors by the complainants.

In the provision, the Authority also emphasized the low level of cooperation demonstrated by the university. The university, in fact, without any justification, did not respond to the Authority's requests, making it necessary for the Special Privacy Unit of the Guardia di Finanza to intervene.

****Notification of Acts and Absence from Hearing****

The notification of acts, and absconding, still without justification, from a hearing that it itself had requested and postponed multiple times. A behavior that has resulted in an unnecessary use of public resources and a delay in the proceedings, elements that the Authority took into account when determining the amount of the sanction.

In addition to the payment of the fine, the Authority has ordered the online university to establish appropriate data retention times - communicating this to the interested parties through the privacy notice - and to provide specific instructions to the staff, so that requests for access to data, opposition, or deletion are fulfilled promptly.

****Inadequate Security Measures: The Authority Sanctions a Local Health Authority****

The healthcare facility had suffered a ransomware attack.

The privacy authority imposed a fine of 30,000 euros on a Neapolitan Local Health Authority (ASL) for failing to adequately protect the personal and health data of 842,000 patients and employees from hacker attacks. The healthcare facility had suffered a ransomware attack that, through a virus, limited access to the facility's database and demanded a ransom to restore the functioning of the systems.

As required by personal data protection regulations, the ASL had communicated the data breach to the Authority, which immediately opened an investigation into the incident to verify the technical and organizational measures adopted by the ASL both before and after the attack.

Several significant critical issues were identified by the Authority following the inspection activity, such as the failure to adopt adequate measures to promptly detect personal data breaches and to ensure the security of networks, also in violation of the principle of data protection by design. Access to the network via VPN occurred through an authentication procedure based solely on the use of a username and password. Furthermore, the lack of network segmentation had caused the virus to spread throughout the entire IT infrastructure.

In sanctioning the unlawful act, the Authority took into account the fact that the data breach involved data capable of revealing health information about a very significant number of individuals, but also the unintentional and cooperative attitude of the ASL. After the incident, the company adopted a series of measures aimed not only at mitigating the damage suffered by the affected individuals but also at reducing the replicability of the event itself, including the activation of a network access procedure via VPN with two-factor authentication.

****Digital Euro: Privacy Authorities Demand Greater Guarantees for Citizens****

For the digital euro, higher privacy standards are needed to gain citizens' trust. This is what the European Data Protection Board (EDPB) and the European Data Protection Supervisor (EDPS) request in their joint opinion on the proposal for a regulation on the digital euro from the European Parliament and the Council.

The digital euro aims to provide individuals with the ability to make electronic payments, both online and offline, in addition to the use of cash. This option is welcomed by the EDPB and EDPS, who have nonetheless made several recommendations for an effective guarantee of the right to privacy and the protection of personal data.

In the opinion, it is particularly requested that only the personal data necessary for the functioning of the digital currency be processed, avoiding the concentration of data by the European Central Bank (ECB) or national central banks, for which the proposed regulation should introduce an explicit obligation for pseudonymization of transaction data.

At the same time, the regulation must clearly specify the responsibilities regarding data protection of each of the actors (ECB, national central banks, payment service providers, and support service providers) participating in the issuance of the digital euro. "With this joint opinion," commented the European Committee, "we aim to ensure that data protection is embedded from the design phase of the digital euro, both online and offline."

****THE AUTHORITY'S ACTIVITIES - FOR THOSE WHO WANT TO KNOW MORE****

The most important interventions and measures recently adopted by the Authority.

"Privacy Tour": the initiative of the Authority for those living in small towns. The goal is to avert the risk of new digital divides.

Project ARC II: 20 free seminars on personal data protection primarily dedicated to small and medium-sized enterprises - October 19, 2023.

****NEWSLETTER of the Authority for the Protection of Personal Data**** (Reg. at the Court of Rome No. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Management and editorial office: Authority for the Protection of Personal Data, Piazza Venezia, No. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it.